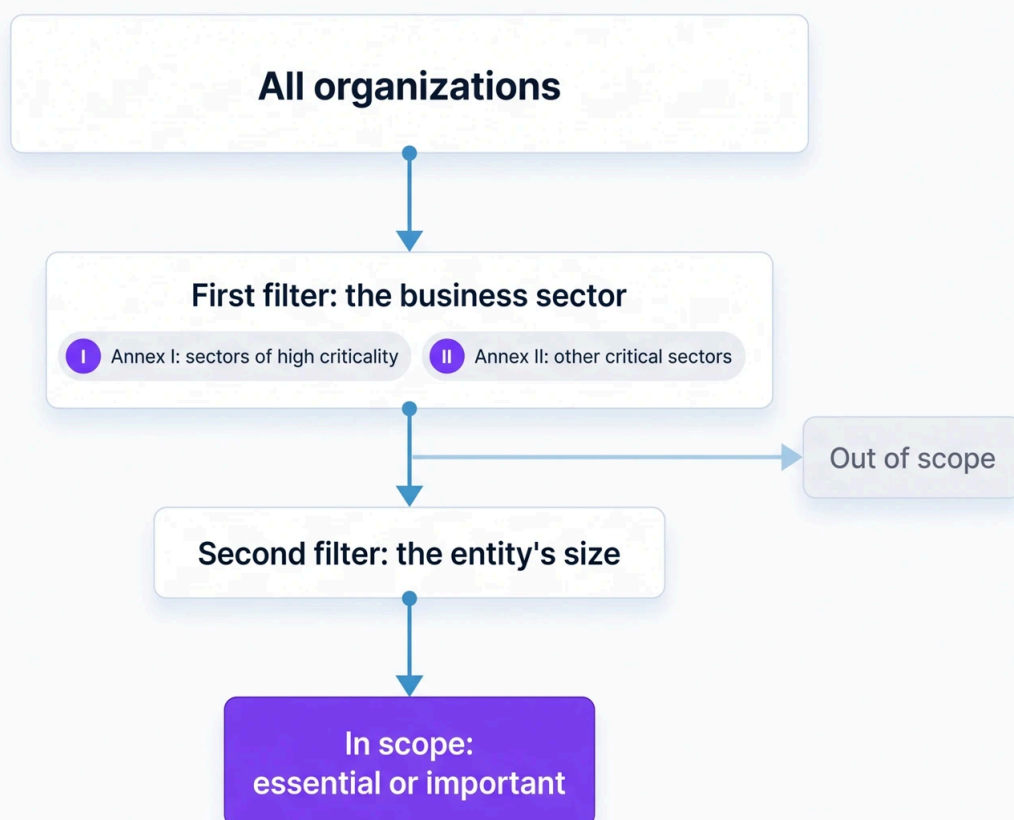


The CISO's briefing: NIS2 applicability

✓ The question senior management will put to the Group CISO (RSSI Groupe) this week



Session objectives

By the end of this sequence:

- **Explain** what the NIS 2 directive is, where it comes from and what it changes compared with NIS 1
- **Distinguish** an essential entity from an important entity, and state what this distinction changes in concrete terms
- **Apply** the applicability criteria (sector of activity, size) to the four subsidiaries of the MERIDIAN group
- **Assess** the actual state of the French transposition and draw from it an honest answer for senior management
- **Relate** the NIS 2 registration obligation to the mapping built in session 2

Prerequisites

- The mapping of the subsidiary under review, built in session 2 from its subsidiary pack: business assets, supporting assets and DICT needs. Together with the reference pack, it is this morning's working material.
- The regulatory context of the subsidiaries set out in session 1: Santé (GDPR, HDS), Logistique (NIS 2), Éducation (GDPR), Territoires (NIS 2, RGS).
- The three levels of governance and the CISO's posture towards decision-makers, covered in session 1.

What to know before the exercise

This briefing sets out the three notions needed, and nothing more: the rest of the regulatory landscape will come in this morning's lecture.

First, the problem the directive was designed to address. For years, European cyber regulation covered only a handful of actors: the first NIS directive, adopted in July 2016 and transposed in France in 2018, targeted, according to ANSSI, the major actors of ten strategic sectors, that is, a few hundred French entities. The result: a mid-sized hospital, a regional logistics operator, a platform serving local authorities flew under the radar, when they are precisely the ones attackers strike. In its Panorama de la cybermenace (cyber threat overview) published in 2026, ANSSI counts 1 366 incidents brought to its attention over the year 2025, with ministries and local authorities accounting for 24 % of them. The threat does not sort its victims by regulatory status.

The NIS 2 directive, then, is the European answer to this coverage gap: Directive (EU) 2022/2555 of 14 December 2022, which succeeds NIS 1 and massively extends the range of organizations subject to cybersecurity obligations. A directive, to be borne in mind from the outset, is not a regulation: it sets a result to be achieved and leaves each Member State to transpose it into its national law. This legal detail will become the heart of the answer to senior management. According to ANSSI, several thousand entities spread across 18 sectors of activity will be concerned in France, and around 600 different types of entities, from public administrations to CAC40 groups.

The applicability criteria answer the question "am I in scope?". The directive's logic comes down to two cumulative filters. First filter, the sector: Annex I lists the "sectors of high criticality" (energy, transport, health, water, digital infrastructure, public administration, space, banking, among others), Annex II the "other critical sectors" (postal and courier services, waste management, manufacturing, digital providers, research, among others). Second filter, size: the directive targets medium-sized enterprises and above. What these criteria do not do: they say nothing about

the actual level of security. An entity can be in scope and well protected, out of scope and vulnerable. Applicability triggers obligations, it measures nothing.

Essential and important entities are the directive's proportionality mechanism. Rather than imposing the same constraints on a national energy operator and on a mid-sized provider, NIS 2 creates two categories. The thresholds published by ANSSI on MonEspaceNIS2: essential entities are those which employ at least 250 people, or whose annual revenue exceeds 50 million euros and annual balance-sheet total 43 million euros, in a sector of high criticality; important entities are those which, without being essential, employ at least 50 people or exceed 10 million euros of revenue and balance-sheet total. The category changes two very concrete things. Supervision: the directive provides, for essential entities, a full supervisory regime, both ex ante and ex post, whereas important entities are supervised only after the fact, upon a report or an incident. And the sanction ceiling: the NIS 2 directive provides for financial penalties of up to 2 % of worldwide turnover for essential entities and 1.4 % for important entities. The limit of this neat mechanism: it rests on special cases and exceptions (certain digital providers are essential whatever their size, States keep room for choices), and this is why the reasoning always goes entity by entity, never in a single sentence.

Essential entity

Ex ante and ex post supervision

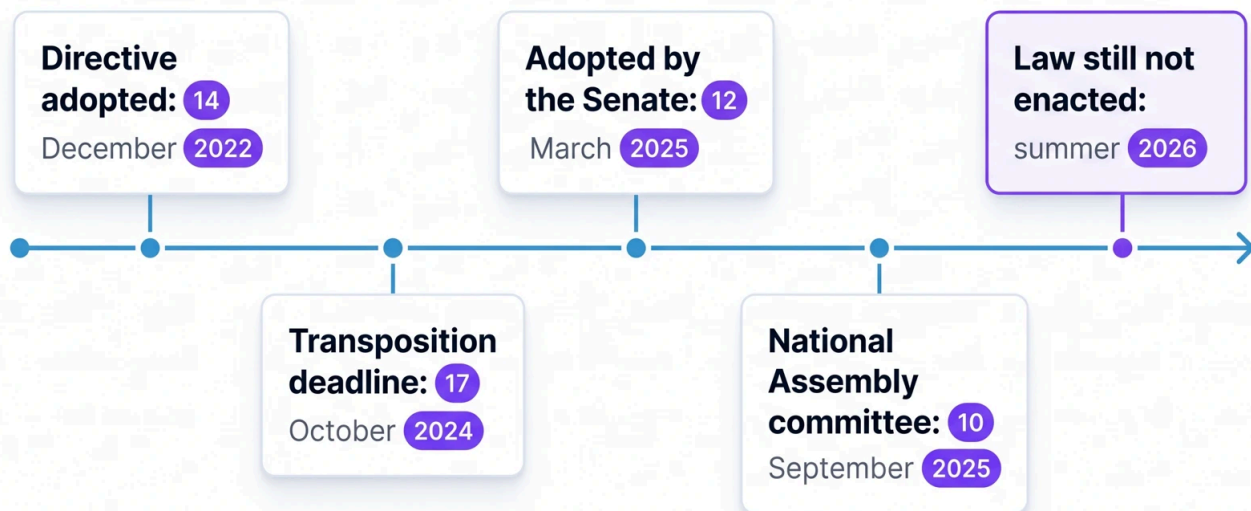
Fines up to **2** % of worldwide turnover

Important entity

Ex post supervision only

Fines up to **1.4** % of worldwide turnover

One last thing before the exercise, and it is a trap many professionals fall into: **being within the scope of the directive does not mean being subject to French obligations today**. The directive set Member States a transposition deadline of 17 October 2024. France has missed it: the bill known as « Résilience » ("Resilience"), which transposes NIS 2, was adopted by the Senate on 12 March 2025, passed by the special committee of the National Assembly on 10 September 2025, and had still not been promulgated as of the summer of 2026. ANSSI states it in black and white: NIS 2 will enter into force in France once the law, its decrees and its orders have been promulgated. In the meantime, the agency invites future regulated entities to prepare, and provides an online applicability test and pre-registration on MonEspaceNIS2. A CISO who answers "we'll see when the law comes out" and a CISO who answers "we are already compliant" are both wrong. The case study builds the third answer.



💡 Method reflex: to determine applicability, always separate what the European text says (stable, published, enforceable) from what national law says (here: still under construction). An answer that mixes the two levels is wrong even when every piece of it is true.

Case study: is the MERIDIAN group concerned, subsidiary by subsidiary?

Scenario and problem statement

Monday morning, 8:40 a.m. The Chief Executive Officer of the MERIDIAN group catches the Group CISO in passing: "Over the weekend I read an article about the R sili nce law and the fifteen thousand companies it covers. Are we among them? Apparently executives are personally liable. I want an answer at Thursday's Executive Committee." She is already gone.

The Group CISO has the mapping built in session 2 (business assets, supporting assets and DICT needs of the subsidiary under review, and the Top 5 of critical assets consolidated in plenary) and the group's figures: MERIDIAN Sant  (healthcare subsidiary), 3 200 employees and 4 care facilities; MERIDIAN Logistique, 2 800 employees and 6 warehouses, with a transport, controlled-temperature warehousing and shipping business run from those warehouses; MERIDIAN  ducation, 900 employees and 45 000 user accounts on its learning portal; MERIDIAN Territoires, 650 employees, operating a citizen services platform for some thirty client local authorities.

This morning's task: prepare the answer to be delivered on Thursday. Not a legal essay, a reasoned characterization, subsidiary by subsidiary, with what it implies.

Guided questions

1. **Classify** each subsidiary against the first filter, the sector: for each one, state the candidate annex (I, II, or outside the annexes) and the closest sector heading. For MERIDIAN Logistique, find TWO possible readings and keep both at this stage (hint: what distinguishes a "transport" activity from a "courier" activity in what the subsidiary actually does?).
2. **Apply** the second filter, size: for each subsidiary retained in question 1, state whether it crosses the essential entities threshold or the important entities threshold, citing the criterion used.
3. **Characterize** each subsidiary provisionally: essential, important, out of scope, or "depends on a choice still open". Each characterization takes one sentence of justification.
4. **Draft** the three sentences to deliver to the Chief Executive Officer on Thursday in answer to "are we among them?", factoring in the actual state of the French transposition. Constraint: none of the three sentences may be proven wrong if the law is promulgated within six months.
5. **Relate** this characterization to the session 2 mapping, for the subsidiary under review: what will Article 3 of the directive require it to communicate to the national authority if it is in scope, and what can the inventory received in session 2 already supply?

Working method

Work subsidiary by subsidiary, in the order Santé, Logistique, Territoires, Éducation: this is the order of increasing difficulty of the reasoning, not the order of the organization chart. For each subsidiary, write down first the fact (actual sector of activity, headcount), then the rule (annex, threshold), then the conclusion: this is the three-step reasoning expected at the session 6 oral, and it is exactly how a lawyer reasons. Refrain from concluding "yes" or "no" when the text does not support a conclusion: being able to say "it depends on a choice France has not yet made" is a skill, not an admission of weakness. Allow 20 minutes for questions 1 to 3, 10 minutes for questions 4 and 5.



Answer keys and assessment criteria — cliquer pour révéler